



JSON Web Token

I. Giới thiệu về JWT

a. Khái niệm

JWT (JSON Web Token) là một chuẩn mở (**RFC 7519**) giúp truyền tải dữ liệu giữa các bên một cách an toàn dưới dạng JSON. JWT được dùng phổ biến để xác thực và trao quyền giữa client và server

b. Cấu trúc

JWT bao gồm ba phần chính, được phân cách bằng dấu chấm (.)

- **Header:** Chứa thông tin về loại token và thuật toán mã hóa được sử dụng, ví dụ HS256.
- **Payload:** Lưu trữ dữ liệu (claims) cần trao đổi. Có ba loại claims:
 - + Registered claims: Thông tin được xác định trước như iss (issuer), exp (expiration), sub (subject).
 - + Public claims: Do người dùng định nghĩa nhưng cần tránh trùng lặp.
 - + Private claims: Được sử dụng để chia sẻ thông tin riêng giữa các bên.
- **Signature:** Bảo vệ JWT khỏi bị giả mạo. Signature được tạo bằng cách mã hóa header và payload với một secret key hoặc private key.

c. Ưu và nhược điểm

- Ưu điểm:
 - + Không cần lưu trữ trạng thái: Server không cần giữ thông tin về người dùng, giúp tăng hiệu quả.



- + Dễ mở rộng: Dữ liệu nhỏ gọn, tiện lợi cho các hệ thống phân tán, dễ truyền tải qua **URL**, tham số **POST**, hoặc trong **header** của **HTTP**.
- Nhược điểm:
 - + Kích thước token lớn: Dữ liệu trong JWT chỉ được mã hóa base64, không ẩn hoặc che giấu nội dung. Do mã hóa base64, JWT có thể lớn hơn so với cookie thông thường.
 - + Không thể thu hồi: Một khi đã cấp, JWT không thể thu hồi mà chỉ có thể chờ hết hạn.

II. Cách JWT hoạt động

- Người dùng gửi thông tin đăng nhập (**username/password**) đến server.
- Server xác thực thông tin và tạo một JWT, sau đó gửi lại client.
- Client lưu trữ JWT (thường là trong **localStorage** hoặc **sessionStorage**) và gửi JWT này trong các yêu cầu tiếp theo.
- Server nhận JWT, kiểm tra signature để xác thực thông tin người dùng.

III. Các hình thức tấn công JWT

- **Tấn công giải mã JWT**: Hacker cố gắng giải mã hoặc giả mạo thông tin bên trong JWT để thực hiện các hành vi trái phép.
- **Tấn công brute-force vào signature**: Kẻ tấn công sử dụng các kỹ thuật brute-force để đoán secret key và làm giả JWT.
- **Replay Attacks**: Hacker gửi lại một JWT đã bị đánh cắp để giành quyền truy cập.

IV. Biện pháp phòng tránh

- Sử dụng secret mạnh và không thể đoán: Đảm bảo secret hoặc private key là mạnh, không dễ đoán để bảo vệ phần signature[1].



- Thiết lập thời gian hết hạn (expiration): Cài đặt thời gian hết hạn ngắn cho JWT để giảm rủi ro tấn công replay.
- Dùng HTTPS: Truyền dữ liệu an toàn bằng cách sử dụng HTTPS để bảo vệ JWT khỏi bị đánh cắp trong quá trình truyền tải.
- Xác thực và kiểm tra claims: Kiểm tra các trường claims và xác thực các giá trị trước khi sử dụng.

V. Nguồn tham khảo

- <https://topdev.vn/blog/gioi-thieu-json-web-token-jwt/>
- <https://viblo.asia/p/tim-hieu-ve-json-web-token-jwt-7rVRqp73v4bP>
- <https://viblo.asia/p/gioi-thieu-ve-json-web-token-jwt-7ymJXPlgJkq>

Mọi thắc mắc hay ý kiến đóng góp vui lòng liên hệ :

Email : r3dctf.info@gmail.com

@Design by R3D CTF Team